

# SunSet srl

## SCHEDA TECNICA DEL SOFTWARE

---

### Simplex

Committente

**Ibis Management srl**

Edizione 1.0

28 agosto 2026

## 1. Scopo e sintesi esecutiva

Simplex un gestionale web monolitico per il governo del ciclo commerciale e operativo di una società di consulenza: anagrafiche, offerte, commesse, attività, fatture, incassi e controllo della produzione.

L'applicazione privilegia un'architettura semplice da distribuire su uno stack PHP/MySQL tradizionale, senza framework applicativo e processo di compilazione front-end.

Il flusso principale parte dall'acquisizione dell'azienda cliente, prosegue con la formulazione dell'offerta e dei relativi momenti di lavoro, genera automaticamente una commessa quando l'offerta diventa Aggiudicata, replica il piano operativo sulla commessa e produce una fattura al completamento di un momento di chiusura. Il pagamento chiude il ciclo amministrativo.

Questa scheda descrive lo stato effettivamente rilevabile dal sorgente. Le funzioni indicate come limiti o raccomandazioni non devono essere considerate già implementate.

## 2. Architettura applicativa

### 2.1 Modello architetturale

Applicazione server-side monolitica e multipagina (MPA): ogni area funzionale corrisponde a uno script PHP raggiungibile direttamente.

Rendering lato server: PHP genera HTML; i form usano richieste GET/POST tradizionali. Una chiamata AJAX impiegata per la creazione rapida dell'azienda nell'editor offerte.

Accesso dati diretto: PDO usato negli script senza ORM, repository layer o migration framework.

Schema auto-inizializzante: numerose pagine eseguono CREATE TABLE IF NOT EXISTS e piccoli ALTER TABLE al caricamento. una strategia di compatibilità incrementale, non un sistema di migrazioni versionato.

Storage ibrido: metadati nel database; allegati nel filesystem sotto uploads/aziende, uploads/offerte e uploads/commesse, organizzati per identificativo del record.

Dipendenze client via CDN: Bootstrap 5.3.3 fornisce griglia, componenti, modali e comportamento responsive; un foglio CSS locale definisce tema e navigazione.

### 2.2 Componenti

Livello | Componenti | Responsabilità

Presentazione | HTML5, Bootstrap, CSS, JavaScript inline | form, tabelle responsive, modali, filtri, calcoli e interazioni

Applicazione | script PHP per modulo | validazione, autorizzazione di base, regole di business, orchestrazione

Servizi comuni | includes/auth.php, includes/layout.php | sessione, identità corrente, login/logout, template e date italiane

Persistenza | PDO + MySQL | query preparate, transazioni selettive, vincoli e dati relazionali

Documentale | filesystem + tabelle \*\_file | caricamento, metadati, visualizzazione e download autenticati

### 2.3 Mappa degli endpoint

Endpoint | Funzione

index.php | reindirizzamento al login

login.php, logout.php, recupera-credenziali.php | accesso, chiusura sessione, reset con password temporanea

bacheca.php | dashboard per ruolo, commesse, scadenze e assegnazione consulenti

utenti.php | anagrafica utenti, stato e ruoli multipli

aziende.php | aziende, sedi, referenti, documenti e classificazioni

enti\_certificazione.php | catalogo enti di certificazione

offerte.php | ciclo di vita offerte, piano attività, documenti e generazione commessa

lavorazioni.php | fasi di lavorazione collegate all'offerta

commesse.php | dati operativi, momenti, completamento, fatture e documenti

fatture.php | consultazione fatture e registrazione/aggiornamento pagamento

pagamenti.php | registro e filtri degli incassi

## 3. Tecnologie utilizzate

### 3.1 Back-end

PHP moderno: type declaration, mixed, nullable type, str\_starts\_with, arrow function e gestione Throwable indicano come requisito pratico PHP 8.0 o successivo.

PDO MySQL: connessione DSN con charset utf8mb4, eccezioni abilitate, fetch associativo e prepared statements nativi (ATTR\_EMULATE\_PREPARES=false).

Sessioni PHP: memorizzano ID, username, nome completo e ruolo principale.

API native: password\_hash/password\_verify, random\_bytes, DateTime, Fileinfo quando disponibile, upload HTTP e streaming con readfile.

### 3.2 Front-end

HTML5 responsive con lingua italiana e viewport mobile.

Bootstrap 5.3.3 CSS/JavaScript da jsDelivr: griglia, card, table, alert, badge, collapse e modal.

CSS locale per sfondo, sidebar scura, menu e intestazioni tabellari.

JavaScript vanilla inline per modali, righe dinamiche dei momenti, calcoli economici, selezione dipendente delle sedi e creazione rapida azienda.

### 3.3 Database e filesystem

MySQL/MariaDB compatibile, engine InnoDB e codifica utf8mb4.

Tipi utilizzati: interi unsigned, YEAR, DATE, DATETIME, TIMESTAMP, DECIMAL, VARCHAR, TEXT, TINYINT ed ENUM.

Vincoli: primary key, unique key, foreign key con CASCADE o SET NULL dove dichiarate.

Allegati salvati con nome fisico casuale e nome originale conservato nel database.

## 4. Funzionalità esaustive

### 4.1 Identità, accesso e sessione

Login tramite nome utente oppure email; sono ammessi solo utenti attivi.

Verifica password mediante hash PHP; password mai confrontate in chiaro.

Logout con svuotamento sessione, scadenza del cookie e distruzione della sessione.

Primo avvio: se non esistono utenti, la pagina utenti consente il bootstrap del primo account.

Recupero credenziali: ricerca per username/email, controllo account attivo, creazione di 8 caratteri esadecimali casuali e immediato aggiornamento dell'hash. La password temporanea mostrata nella pagina; non inviato alcun messaggio email.

Non risulta implementata la funzione promessa di cambio password successivo al login.

### 4.2 Utenti e autorizzazioni

Creazione e modifica di username, nome, cognome, telefono, email, password e stato attivo.

Validazione email, obbligatorietà, password minima di 8 caratteri e gestione errori di unicità.

Ruoli disponibili: Amministratore, Responsabile di Area, Consulente.

Relazione molti-a-molti utenti\_ruoli; il campo storico utenti.ruolo rimane come ruolo principale/fallback.

Dashboard: amministratore e responsabile di area vedono tutte le commesse; il consulente semplice vede quelle assegnate al proprio nome. Il profilo contemporaneamente Consulente e Responsabile di Area pu assegnare o riassegnare le commesse aggiudicate.

Le altre pagine richiedono in generale soltanto una sessione autenticata: non emerge un controllo granulare di ruolo per ciascuna operazione CRUD.

### 4.3 Bacheca

Riepilogo delle commesse secondo la visibilit del ruolo.

Elenco di protocollo commessa/offerta, azienda, servizio, stato e data di creazione.

Vista delle offerte aggiudicate ordinata per scadenza crescente per amministratori/responsabili.

Assegnazione consulente in modale, con token CSRF, validazione su elenco consulenti attivi e transazione con blocco FOR UPDATE.

Aggiornamento coordinato del consulente su offerta e commessa.

### 4.4 Anagrafica aziende

CRUD dell'azienda con partita IVA, codice fiscale, ragione sociale, IBAN, tipologie multiple, codice fatturazione, recapiti, PEC, email, sito e indirizzo.

Classificazione commerciale: RCO, segnalatore, categoria merceologica, settore EA, fascia di organico, fascia di fatturato, canale di conoscenza, prodotti, note e azienda promotrice.

Partita IVA normalizzata e validata a 11 cifre, univoca; ragione sociale limitata a 30 caratteri.

Tipologie: Promotore, Fornitore, Partner e Cliente; fasce organico 0-10, 10-50, 50-250 e 250+.

Gestione di pi sedi Legale/Amministrativa/Operativa con indirizzo strutturato.

Gestione di pi referenti con nome, telefono, email e ruolo.

Salvataggio atomico di azienda, sedi e referenti mediante transazione; le collezioni figlie sono riallineate con cancellazione e reinserimento.

Vista dettaglio, elenco e ricerca estesa su campi anagrafici, geografici e classificativi.

Upload e consultazione documenti associati.

Creazione rapida da offerta con risposta JSON e aggiornamento immediato della select cliente.

### 4.5 Enti di certificazione

Inserimento della denominazione, elenco alfabetico e cancellazione.

L'ente selezionabile nelle commesse relative a servizi di sistemi di gestione aziendale, con relativo importo economico.

### 4.6 Offerte

Protocollo progressivo annuale nel formato numero/anno, con vincoli di unicit.

Stati: In Elaborazione, Inviata, Aggiudicata, Scaduta; gli stati storici Generata e In Lavorazione vengono normalizzati.

Servizi: sistemi di gestione aziendale, sicurezza, formazione, finanza agevolata, consulenza SOA e altre consulenze.

Catalogo dettagliato di certificazioni/consulenze, incluse norme ISO, GDPR, HACCP, sicurezza, formazione e finanza agevolata.

Collegamenti ad azienda, sede di erogazione, RCO, segnalatore, promotore e consulente incaricato.

Dati commerciali: data, validit, scadenza, specifiche, note, modalit di pagamento, commissione e sconto percentuale.

Piano dei momenti con data, tipologia, costo totale, valore giornaliero, giorni e ore; totale lordo, sconto e totale netto sono calcolati per la presentazione.

Allegati con visualizzazione inline e download.

Filtri per protocollo, servizio, stato, date e consulente; dettaglio dell'offerta e collegamento alla commessa.

Cancellazione dell'offerta; ove presenti i vincoli, la cancellazione propaga ai dati figli.

#### 4.7 Generazione della commessa

Al salvataggio di un'offerta Aggiudicata con consulente, ensureCommessa crea una sola commessa grazie all'unicità di offerta\_id.

Il protocollo progressivo per anno nel formato numero/anno.

Il codice consulente derivato dai primi due caratteri del nome completo; il nome duplicato sulla commessa come fotografia operativa.

I momenti dell'offerta sono copiati nella tabella dei momenti della commessa.

Se la commessa esiste già, viene aggiornato il consulente senza duplicarla.

#### 4.8 Lavorazioni e momenti operativi

Sono presenti due rappresentazioni correlate:

1. Fasi di lavorazione offerta (offerta\_lavorazioni): apertura/chiusura lavori, importo, data prevista, flag di fatturazione, valore giorno-uomo, ore e giorni, con crea/modifica/elimina.
2. Momenti di lavorazione (offerta\_moment\_lavorazione e commessa\_moment\_lavorazione): Apertura, Consegna Documento di Sistema e Chiusura, con costo totale, incontri, studio, previsione e stato di completamento.

Nella commessa possibile aggiungere momenti, completare un momento una sola volta e vedere l'eventuale fattura collegata.

#### 4.9 Commesse

Elenco delle commesse generate e ricerca per protocollo, cliente, consulente, offerta, data R.A.L.I., DTG, budget, servizio e dettaglio.

Dati operativi: protocollo/anno, consulente, data R.A.L.I., utente DTG, budget, cliente, ente di certificazione e relativo importo.

Gestione dei momenti e dei relativi indicatori di completamento.

Upload, visualizzazione e download dei documenti di commessa.

#### 4.10 Fatturazione e pagamenti

Completando un momento di tipo Chiusura, viene creata automaticamente una fattura se non ne esiste già una per quel momento.

Numero fattura univoco basato sull'identificativo e sull'anno; importo ricavato dal costo totale del momento.

Registro fatture con numero, anno, commessa, importo, stato pagata/non pagata, dettaglio e filtri.

Registrazione pagamento in modale: data e modalità tra Contanti, Bonifico e Carta di Credito.

Un pagamento per fattura: il nuovo invio aggiorna l'incasso esistente; la fattura viene marcata pagata.

Registro pagamenti con fattura, commessa, importo, data, modalità e data di creazione, corredato da filtri.

#### 4.11 Amministrazione / Produzione

Report tabellare delle commesse con anno, consulente, offerta/stato, data R.A.L.I., DTG, budget e cliente.

Filtri testuali, esatti, data e intervallo budget.

Calcolo del totale budget delle sole righe risultanti dal filtro.

## 5. Modello dati

### 5.1 Entit principali

Tabella | Contenuto e relazioni principali

utenti | credenziali, profilo, ruolo principale, stato

utenti\_ruoli | ruoli multipli; chiave composta e cascata su utente

aziende | anagrafica estesa; riferimenti a utenti RCO/segnalatore e promotore

aziende\_sedi | sedi multiple, cascata su azienda

aziende\_referenti | contatti multipli, cascata su azienda

aziende\_file | metadati allegati azienda

enti\_certificazione | catalogo enti

offerte | protocollo, stato, servizio, relazioni commerciali e condizioni

offerte\_file | metadati allegati offerta

offerta\_lavorazioni | fasi economico-temporali dell'offerta

offerta\_momenti\_lavorazione | piano dei momenti da trasferire alla commessa

commesse | esecuzione dell'offerta aggiudicata; offerta\_id univoco

commesse\_file | metadati allegati commessa

commessa\_momenti\_lavorazione | piano operativo, completamento e valori economici

fatture | una fattura per momento tramite momento\_id univoco

pagamenti | un pagamento per fattura tramite fattura\_id univoco

### 5.2 Cardinalit logiche

Utente 1:N Aziende come RCO o segnalatore; Utente N:M Ruoli.

Azienda 1:N Sedi, Referenti, File e Offerte.

Offerta 1:N File/Lavorazioni/Momenti e 1:0..1 Commessa.

Commessa 1:N Momenti/File/Fatture.

Momento commessa 1:0..1 Fattura; Fattura 1:0..1 Pagamento.

### 5.3 Integrit e progressivi

Unicit esplicita per username, partita IVA, protocolli, coppie numero/anno, offerta della commessa, momento fatturato e fattura pagata.

Importi monetari memorizzati prevalentemente come DECIMAL(12,2) per evitare errori binari persistenti.

Progressivi ottenuti con MAX(...) + 1: la chiave univoca protegge dai duplicati, ma richieste concorrenti possono produrre un errore da gestire/riprovare.

## 6. Tecniche di implementazione

### 6.1 Validazione e normalizzazione

Input ripuliti con trim, cast espliciti, whitelist tramite in\_array, filter\_var per email e regex per date/P.IVA.

Importi italiani accettano la virgola e vengono normalizzati al punto.

Helper data riconosce formati ISO e italiani e visualizza gg/mm/aaaa.

Output dinamico HTML protetto prevalentemente con htmlspecialchars; note multilinea con nl2br dopo escaping.

Redirect dopo alcune mutazioni per evitare reinvi; messaggi temporanei in sessione nella dashboard.

## 6.2 Persistenza e transazioni

Query preparate e parametri nominati nella maggior parte dei percorsi.

Transazioni nelle operazioni composte pi sensibili: riallineamento azienda/sedi/referenti e assegnazione consulente.

FOR UPDATE protegge l'offerta durante l'assegnazione dalla bacheca.

Le pagine verificano la presenza di tabelle/colonne e applicano evoluzioni compatibili durante l'esecuzione.

## 6.3 Gestione documentale

Directory create con permessi 0775; file spostati con move\_uploaded\_file.

Nome originale separato dal nome fisico; MIME determinato lato server quando Fileinfo disponibile.

Endpoint di download verificano sessione, ID, record e presenza del file, impostano MIME, lunghezza e Content-Disposition inline/attachment.

# 7. Sicurezza: misure presenti e valutazione

## 7.1 Misure presenti

Hash password tramite algoritmo predefinito aggiornabile di PHP.

Token casuali crittograficamente sicuri per password temporanea e CSRF della riassegnazione.

Prepared statement PDO nativi, riducendo l'esposizione a SQL injection.

Escape dell'output HTML, controlli di sessione e download non pubblici.

Whitelist per ruoli, stati e modalit di pagamento in diversi flussi.

InnoDB, vincoli univoci e foreign key in molte tabelle.

## 7.2 Lacune e rischi da trattare prima di una produzione esposta

1. Credenziali database nel sorgente: host, database, utente root e password vuota devono essere trasferiti in variabili d'ambiente/secrets e sostituiti con un account a privilegi minimi.
2. CSRF non uniforme: il token compare nell'assegnazione da bacheca, ma non in tutti i form mutativi (CRUD, upload, pagamento, cancellazioni).
3. Autorizzazione troppo ampia: salvo la dashboard, un utente autenticato pu generalmente raggiungere le aree amministrative; serve RBAC centralizzato per azione e risorsa.
4. Recupero password: la password temporanea mostrata a chi conosce username/email, senza prova di possesso, scadenza, token monouso o rate limiting.
5. Session hardening: non visibile rigenerazione dell'ID al login n configurazione esplicita Secure, HttpOnly, SameSite, durata e timeout inattivit.
6. Upload: non emergono limiti applicativi espliciti di dimensione/estensione, scansione malware o whitelist MIME; i file vanno conservati fuori dalla document root.
7. Header HTTP: mancano policy CSP, HSTS, X-Content-Type-Options, frame policy e referrer policy.
8. Error disclosure: l'errore PDO di connessione viene mostrato direttamente; in produzione va registrato lato server e sostituito con messaggio neutro.
9. Audit: non esiste un registro applicativo immutabile di accessi e modifiche.
10. Configurazione CDN: Bootstrap dipende dalla rete e non usa Subresource Integrity nel markup rilevato.

# 8. Requisiti di esercizio e installazione

## 8.1 Requisiti minimi consigliati

Web server Apache 2.4 o Nginx recente con HTTPS.

PHP 8.0+; consigliato PHP 8.2/8.3 compatibile con la versione di produzione.

Estensioni PHP: pdo, pdo\_mysql, session, mbstring, fileinfo; accesso a random\_bytes e funzioni password.

MySQL 8.x o MariaDB equivalente con InnoDB e utf8mb4.

Filesystem persistente scrivibile per uploads/; spazio dimensionato sulla retention documentale.

Accesso a jsDelivr oppure distribuzione locale degli asset Bootstrap.

## 8.2 Procedura logica

1. Pubblicare i sorgenti nella document root configurando HTTPS.
2. Creare database e utente applicativo; impostare connessione senza conservare segreti nel repository.
3. Concedere inizialmente i privilegi necessari alla creazione/alterazione schema, oppure estrarre le DDL in migrazioni amministrative e poi revocarli.
4. Creare e proteggere le directory upload, preferibilmente fuori dall'area pubblica.
5. Accedere a utenti.php su database vuoto e creare il primo amministratore.
6. Eseguire smoke test di login, anagrafiche, offerta aggiudicata, commessa, chiusura, fattura, pagamento e download.

## 8.3 Backup e ripristino

Il backup consistente solo se comprende insieme dump MySQL e directory upload.

Prevedere backup cifrati, retention, verifica automatica e prove periodiche di ripristino.

Prima di un rilascio effettuare snapshot di database e documenti; le DDL runtime non forniscono rollback automatico.

## 9. Operatività, qualità e manutenibilità

Non risultano presenti Composer, framework, test automatici, CI/CD, logging strutturato, monitoraggio o file di configurazione per ambienti.

La navigazione laterale duplicata negli script: una modifica di menu richiede interventi multipli.

Regole, DDL, accesso dati e HTML convivono negli stessi file; ci accelera prototipazione e piccoli interventi ma aumenta accoppiamento e costo dei test.

La definizione schema ripetuta e non sempre omogenea tra moduli; una migration unica e versionata ridurrebbe il rischio di drift.

Sono presenti sia offerta\_lavorazioni sia offerta\_momenti\_lavorazione: va chiarito il confine funzionale o pianificata una convergenza per evitare duplicazioni informative.

## 10. Raccomandazioni prioritarie

### Priorità alta

1. Esternalizzare configurazione/segreti e usare un account DB dedicato.
2. Introdurre CSRF globale, RBAC server-side, rigenerazione sessione e recupero password con link firmato, scadenza e verifica email.
3. Blindare upload/download: limiti, whitelist, antivirus, storage esterno alla web root e header sicuri.



4. Versionare lo schema in migrazioni; eliminare DDL dalle richieste utente.
5. Aggiungere test di integrazione sui flussi economici e autorizzativi.

### Priorit media

6. Centralizzare layout/menu, autorizzazioni, upload e servizi applicativi.
7. Rendere atomici generazione commessa, copia momenti, completamento e fatturazione; gestire collisioni dei progressivi.
8. Aggiungere audit trail, log strutturati, gestione errori e metriche.
9. Definire cancellazione logica/retention per documenti fiscali e commerciali.

### Priorit evolutiva

10. Separare livelli controller/service/repository, introdurre dependency management e pipeline CI.
11. Accessibilit WCAG, test responsive/browser e asset front-end locali/versionati.
12. Esportazioni PDF/CSV, notifiche di scadenza e riconciliazione pagamenti, se richieste dal processo aziendale.

## 11. Matrice sintetica di tracciabilit

Processo | Ingresso | Elaborazione | Uscita

Accesso | username/email + password | verifica account e hash | sessione autenticata

Acquisizione cliente | anagrafica, sedi, referenti | validazione e transazione | azienda ricercabile

Preventivazione | servizio, cliente, condizioni, momenti | progressivo e calcoli | offerta protocollata

Aggiudicazione | stato + consulente | creazione idempotente e copia momenti | commessa protocollata

Esecuzione | momenti e dati produzione | avanzamento/completamento | stato operativo

Fatturazione | completamento chiusura | unicit per momento e importo | fattura

Incasso | data + modalit | upsert pagamento e stato pagata | registro pagamenti

Controllo | filtri | join e aggregazione budget | viste operative

## 12. Conclusione

Simplex copre in modo coerente il ciclo essenziale cliente -> offerta -> commessa -> lavorazione -> fattura -> pagamento, con un modello dati relazionale, protocolli annuali, gestione documentale e viste per il controllo operativo. La base tecnica comprensibile e distribuibile con uno stack LAMP classico. Per una messa in esercizio robusta e conforme alle aspettative di un sistema amministrativo, le azioni pi importanti sono il consolidamento di sicurezza e autorizzazioni, la migrazione versionata del database, la protezione documentale e l'introduzione di test, audit e procedure operative formalizzate.

Fine documento - SunSet srl - Committente: Ibis Management srl